Infraestructura de Servicios Blockchain de España

INF1040 - Política de gestión de nodos

Proyecto ISBE	**Autor** José Antonio Fernández
Fecha 19.12.2025	**Colaboradores** Juan Luis Gonzalo GT Gobernanza

Financiado por la Unión Europea NextGenerationEU
Plan de Recuperación, Transformación y Resiliencia
Comunidad de Madrid
ALASTRIA

Índice

1. Objeto y alcance 2
2. Definiciones y marco de referencia 4
2.1 Definiciones clave de infraestructura 4
2.2 Definiciones de seguridad y operación 4
2.4 Reglas de interpretación 5
3. Principios 6
4. Roles y responsabilidades 7
4.1 Roles del ecosistema 7
4.2 Matriz RACI 8
5. Reglas obligatorias 9
5.1 Reglas de arquitectura y topología 9
5.2 Reglas de seguridad lógica (bastionado) 9
5.3 Reglas de interacción y filtrado 9
5.4 Reglas de operación y mantenimiento 10
5.5 Reglas de infraestructura y conectividad 10
6. Procedimientos clave 12
6.1 Proceso de permisionado (alta de nodo) 12
6.2 Proceso de actualización de software (mantenimiento) 13
6.3 Proceso de baja voluntaria (*Offboarding*) 13
6.4 Proceso de deshabilitación forzosa (sanción) 14
6.5 Procedimiento de rotación de validadores 15
7. Supervisión, revisión y actualización 17
7.1 Objetivo y alcance de la supervisión 17
7.2 Indicadores y umbrales (KPI mínimos) 17
7.3 Revisión y actualización de la política 17
8. Anexos 18
8.1 Guía técnica de bastionado 18

1. Objeto y alcance

Esta política establece el marco normativo, los requisitos técnicos imperativos y los procedimientos de operación para la gestión del ciclo de vida de los nodos que conforman la infraestructura ISBE.

Su finalidad es garantizar la integridad, disponibilidad y seguridad del registro distribuido, asegurando que todos los puntos de conexión a la red operan bajo estándares homogéneos de rendimiento, bastionado (*hardening)* y cumplimiento normativo, independientemente de si son operados por ISBE o por Participantes externos.

Resultados esperados

- **Integridad estructural:** Aseguramiento de la red mediante una tipología de nodos estandarizada y segmentada (Ejecución vs. Consenso).
- **Seguridad perimetral:** Implementación obligatoria de capas de filtrado transaccional (*Proxy/Middleware*) para proteger el núcleo de la red.
- **Soberanía de claves:** Custodia segura de materiales criptográficos mediante gestores de secretos (*Secret Managers*), eliminando riesgos de exposición.
- **Sostenibilidad:** Optimización del consumo de recursos mediante requisitos de hardware eficiente y algoritmos de consenso de bajo impacto (QBFT).

Ámbito de aplicación

Esta política aplica a:

- **Activos:** Todos los nodos (físicos o virtuales) conectados a cualquier entorno de ISBE (Red Bare y Redes de Casos de Uso), incluyendo Nodos de Ejecución, Validadores, *Bootnodes* y Nodos de Archivo.
- **Actores:** Todos los Participantes con nivel de autorización para operar infraestructura (Niveles Operador de Nodo de Ejecución y Operador de Nodo de Consenso) y el personal técnico de ISBE.

Relación con otros documentos

- ***ECO1020 - Política de gestión de casos de uso y SCs:*** Define la lógica de negocio que ejecutan los nodos.
- ***INF1050 - Política de gestión de identidades digitales, credenciales y accesos:*** Regula las credenciales necesarias para el permisionado del nodo.

- ***INF1070 - Política de seguridad de la información:*** Establece los controles de seguridad generales (ENS) que deben aplicar los operadores.

- ***INF1080 - Política de gestión de incidencias:*** Define los SLAs de disponibilidad que los nodos deben cumplir.

Marco de referencia

La aplicación de esta política se alinea con:

- **Esquema Nacional de Seguridad (ENS):** Requisitos de bastionado (guías CCN-STIC) y protección de infraestructuras.

- **Reglamento eIDAS2:** Requisitos de seguridad para la prestación de servicios de confianza (EBSI/LME).

- **Estándares ISO/IEC 27001:** Controles de seguridad física y lógica.

- **Directiva NIS2:** Gestión de riesgos en la cadena de suministro y seguridad de las redes.

Fuera de alcance

- La seguridad física de los Centros de Procesamiento de Datos (CPD) de terceros proveedores de nube (AWS, Azure, etc.), aunque el Participante es responsable de verificar sus certificaciones (ISO 27001/ENS).

- La lógica de negocio interna de los *Smart Contracts* desplegados en los nodos (objeto de la *ECO1020 - Política de gestión de casos de uso y SCs)*.
- La gestión de las redes locales (LAN) o dispositivos de usuario final que se conectan a los nodos, fuera del perímetro del *Proxy* de Gobernanza.

2. Definiciones y marco de referencia

2.1 Definiciones clave de infraestructura

- **Nodo de ejecución (*Execution Node*):** Punto de entrada estándar para la interacción con la red. Mantiene una copia del estado, procesa transacciones y permite la lectura/escritura mediante RPC. No participa en la validación de bloques.

- **Nodo de consenso (*Validator Node*):** Nodo crítico dedicado exclusivamente a la ejecución del algoritmo de consenso QBFT (*Quorum Byzantine Fault Tolerance*). Valida transacciones, propone bloques y asegura la finalidad de la cadena. No expone APIs públicas.

- **Nodo de arranque (*Bootnode*):** Nodo de infraestructura operado por ISBE que facilita el descubrimiento de pares (*peer discovery*) y gestiona la lista blanca de conexiones permitidas (*allowlist*).

- **Nodo de archivo (*Archive Node*):** Nodo especializado que almacena el histórico completo de estados desde el bloque génesis, permitiendo auditorías forenses y trazabilidad profunda.

2.2 Definiciones de seguridad y operación

- **Proxy de gobernanza:** Componente de infraestructura (tipo NGINX o similar) que actúa como cortafuegos transaccional, interceptando y validando todas las peticiones externas antes de que lleguen al nodo.

- **Middleware de filtrado:** Capa de lógica intermedia que aplica reglas de negocio y cumplimiento sobre las transacciones RPC en tiempo real.

- **Gestor de secretos *(Secret Manager*):** Sistema de almacenamiento seguro (HSM o servicio *Cloud*) para la custodia de las claves privadas del nodo, garantizando que nunca se expongan en texto claro en el sistema de ficheros.

- **Permisionado (*Permissioning*):** Mecanismo de control de acceso a nivel de red (P2P) que impide la conexión de nodos no autorizados o no identificados.

- **Bastionado (*Hardening*):** Proceso de reducción de la superficie de ataque del sistema operativo y del software del nodo mediante la deshabilitación de servicios innecesarios y la aplicación de configuraciones restrictivas.

2.3 Marco de referencia

Esta política se desarrolla en conformidad con el marco legal de ISBE y se alinea con:

- **Esquema Nacional de Seguridad (ENS - RD 311/2022):** Obligatoriedad de aplicar guías de bastionado (CCN-STIC) y protección de infraestructuras.
- **Reglamento eIDAS2:** Requisitos de seguridad para la prestación de servicios de confianza y cualificación de libros mayores electrónicos (EBSI/LME).
- **Estándar ISO/IEC 27001:** Controles de seguridad física y lógica para centros de datos y operaciones.
- **Directiva NIS2 y DORA:** Gestión de riesgos en la cadena de suministro, notificación de incidentes y resiliencia operativa digital

2.4 Reglas de interpretación

- **Responsabilidad del operador:** La autorización para conectar un nodo a ISBE implica la asunción plena de responsabilidad por parte del Participante sobre la seguridad física, lógica y operativa de dicho activo. Un nodo comprometido es responsabilidad de su operador.
- **Prevalencia de la seguridad:** En caso de conflicto entre rendimiento y seguridad, prevalecerán siempre los controles de seguridad y cumplimiento normativo.

3. Principios

La gestión de nodos en ISBE se rige por los siguientes principios rectores, alineados con la estrategia de **Seguridad por Diseño** y la **Memoria de Gobernanza**:

1. **Defensa en profundidad:** La seguridad no depende de una única barrera. Se exige una arquitectura en capas: Seguridad Física - Bastionado del SO - *Proxy/Firewall* - *Middleware* de Filtrado - Nodo. Ningún nodo de ejecución puede exponer sus puertos RPC directamente a Internet.
2. **Mínimo privilegio y aislamiento:** Los Nodos de Consenso deben operar en entornos aislados, dedicados exclusivamente a la validación, sin exponer interfaces de consulta ni permitir el despliegue de contratos. Su función es crítica y debe estar blindada frente a tráfico general.
3. **Custodia segura de claves:** Las claves privadas (identidad del nodo y firma de bloques) son el activo más sensible. Se prohíbe su almacenamiento en texto plano. Es obligatorio el uso de *Secret Managers* o módulos de seguridad *hardware* (HSM) para su generación, custodia y uso.
4. **Identificación y permisionado estricto:** No existen "nodos anónimos" en ISBE. Todo nodo conectado debe estar vinculado criptográficamente a la identidad (DID) de un Participante verificado. El permisionado se aplica a nivel de red (conexión P2P) y a nivel de servicio (RPC).
5. **Observabilidad y auditoría:** Todo operador debe implementar capacidades de monitorización continua y registro de eventos (*logging*). ISBE se reserva el derecho de auditar el estado de cumplimiento de los nodos y de desconectar aquellos que no cumplan los SLAs o presenten comportamientos anómalos.
6. **Sostenibilidad energética:** Se prioriza el uso de hardware eficiente y configuraciones optimizadas para minimizar la huella de carbono, aprovechando la eficiencia nativa del consenso QBFT frente a modelos intensivos en energía.

Financiado por la Unión Europea NextGenerationEU
Gobierno de España Ministerio para la Transformación Digital y de la Función Pública
Plan de Recuperación, Transformación y Resiliencia
Comunidad de Madrid
ALASTRIA

4. Roles y responsabilidades

La gestión de nodos en ISBE se asigna estrictamente en función del Nivel de Participación formalizado en el Contrato Marco de Adhesión (CMA). No todas las entidades tienen capacidad para operar infraestructura.

4.1 Roles del ecosistema

- **Órgano de Gestión:** Aprueba la presente política y sus modificaciones sustanciales. Decide sobre cambios estructurales en la arquitectura de red.
- **Órgano de Supervisión:** Ratifica las decisiones de expulsión o deshabilitación forzosa de nodos críticos (validadores) para asegurar la neutralidad y evitar la arbitrariedad en la gestión de la infraestructura.
- **Comité de Operaciones y Tecnología:** Define los requisitos técnicos de los nodos (*hardware*, versiones), los estándares de bastionado y los umbrales de rendimiento (SLA). Ejecuta el proceso técnico de permisionado (alta en *allowlist*), monitoriza el rendimiento de los nodos y ejecuta las bajas o bloqueos técnicos.
- **Comité de Seguridad:** Define los controles de ciberseguridad obligatorios (ENS), las políticas de gestión de claves y valida las guías de bastionado.
- **Participante:** Es el responsable único de la instalación, mantenimiento, seguridad y actualización de sus nodos, así como de garantizar la custodia de sus claves privadas.
    - **Operador de Nodo de Ejecución:** Despliega infraestructura propia para dar servicio a sus aplicaciones o a terceros, sin usar el servicio BaaS de ISBE. Es responsable de la seguridad del acceso (RPC), de implementar los filtros de gobernanza (*Proxy/Middleware*) ante sus usuarios y de mantener el registro *off-chain* de los mismos.
    - **Operador de Nodo de Consenso (Validador):** Entidad crítica que opera un nodo dedicado exclusivamente a la validación de bloques y participación en el consenso QBFT. Debe garantizar la disponibilidad (*uptime* > 99.9%) y la integridad del proceso. Está obligado a operar en entornos aislados, cumplir SLAs estrictos y participar en la rotación de validadores.
- **ISBE (Entidad Gestora):** Responsable único de la **Red Bare** y de los servicios críticos de infraestructura central: Nodos de Arranque (*bootnodes*) y Nodos de Archivo (*archive*). Garantiza la "zona desmilitarizada" (DMZ) de la red.

4.2 Matriz RACI

La siguiente matriz define las responsabilidades en los procesos de intervención y gestión de derechos:

Proceso / Decisión	Operador de Nodo de Ejecución	Operador de Nodo de Consenso	Comité de Operaciones y Tecnología	Comité de Seguridad	Órgano de Gestión
Definición de requisitos técnicos	I	I	R	C	A
Solicitud de alta de nodo	R	R	A	I	—
Auditoría de bastionado	I	I	R	C	—
Ejecución técnica (*whitelist*)	I	I	R	—	—
Validación de bloques	—	R	I	I	—
Deshabilitación	I	I	R	C	A

Leyenda:

Sigla	Significado	Descripción breve
R	*Responsible*	Ejecuta la acción.
A	*Accountable*	Aprueba/decide la acción y asume la responsabilidad final.
C	*Consulted*	Consulta preceptiva antes de decidir/ejecutar.
I	*Informed*	Informado del resultado/decisión.

5. Reglas obligatorias

La conexión de cualquier dispositivo a la red ISBE está condicionada al cumplimiento permanente de las siguientes reglas de seguridad y arquitectura.

5.1 Reglas de arquitectura y topología

Regla 1. Segmentación de red (DMZ).

La red no opera en malla completa abierta. Los Nodos de Consenso nunca deben exponerse directamente a tráfico general. La comunicación debe triangularse a través de *Bootnodes* o capas de protección controladas para reducir la superficie de ataque.

Regla 2. Prohibición de nodos anónimos.

Todo nodo debe estar identificado criptográficamente (*Enode ID*) y vinculado a un Participante verificado (DID). El "permisionado" se aplica a nivel de protocolo (P2P): cualquier conexión entrante de un nodo no listado en la *allowlist* debe ser rechazada automáticamente.

5.2 Reglas de seguridad lógica (bastionado)

Regla 3. Bastionado del sistema operativo *(hardening).*

Es obligatorio aplicar una configuración de seguridad restrictiva sobre el sistema operativo (Linux) que aloja el nodo. Esto incluye, como mínimo: desactivación de servicios no esenciales, cierre de puertos no utilizados, y configuración de *firewalls* locales (*iptables/ufw*). El incumplimiento de esta regla es causa de revocación del permiso.

Regla 4. Custodia de claves *(Secret Management).*

Queda terminantemente prohibido almacenar las claves privadas del nodo (*nodekey*) o del firmante (*mining key*) en archivos de texto plano en el disco del servidor. Es obligatorio el uso de Gestores de Secretos (Vault, HSM, AWS KMS, Azure Key Vault) para la inyección segura de credenciales en tiempo de ejecución.

Regla 5. Sincronización horaria (NTP).

Todos los nodos deben sincronizar su reloj mediante el protocolo NTP con servidores de tiempo fiables. La desincronización superior a 500ms es crítica para el consenso QBFT y motivo de alerta.

5.3 Reglas de interacción y filtrado

Regla 6. Protección RPC *(Proxy* de gobernanza).

Ningún Nodo de Ejecución puede exponer sus puertos JSON-RPC (8545) directamente. El acceso debe estar mediado por un Proxy Inverso con autenticación (API Keys), cifrado TLS y limitación de tasa (*rate-limiting*).

Regla 7. Filtrado transaccional (*Middleware).*

Los operadores deben implementar el componente "Middleware de Filtrado" homologado por ISBE. Este sistema interceptará las transacciones para bloquear operaciones no conformes (ej. listas de sanciones) antes de que entren en la *mempool.*

5.4 Reglas de operación y mantenimiento

Regla 8. Gestión de *logs* y auditoría.

Se debe activar el servicio de auditoría del sistema (*auditd*) y mantener un registro de eventos (*logs*) de sistema y de la aplicación Besu por un periodo mínimo de 30 días, preferiblemente exportados a un sistema centralizado para evitar su manipulación.

Regla 9. Ciclo de vida del software.

Es obligatorio aplicar los parches de seguridad del Sistema Operativo y actualizar el cliente Hyperledger Besu a las versiones soportadas por ISBE en un plazo máximo de 15 días tras su publicación oficial.

Regla 10. Disponibilidad (SLA).

- **Nodos de Consenso**: Disponibilidad mínima del **99.9%** mensual. La caída por debajo de este umbral o la no participación en rondas de firma conllevará penalizaciones.
- **Nodos de Ejecución:** Disponibilidad mínima del **99.5%**.

Regla 11. Rotación de validadores.

Los Operadores de Nodos de Consenso aceptan someterse a los mecanismos de rotación automática (Activo-*Stand-by*) dictados por el contrato de gobernanza para garantizar la descentralización.

5.5 Reglas de infraestructura y conectividad

Regla 12. Hardware delicado.

Los nodos deben desplegarse sobre recursos reservados (no compartidos) para garantizar el rendimiento. Se prohíbe el uso de discos mecánicos (HDD); el almacenamiento debe ser SSD/NVMe de alta velocidad (mínimo 3.000 IOPS) para soportar la escritura de la base de datos.

Regla 13. Política de puertos (*firewall*).

- El puerto P2P (30303) solo aceptará conexiones de IPs autorizadas (*allowlist*).
- Los puertos RPC (8545) y WS (8546) deben estar cerrados al exterior (0.0.0.0 bloqueado) y ser accesibles únicamente a través del *Proxy/Middleware*.

6. Procedimientos clave

Los siguientes procedimientos regulan el ciclo de vida completo de los nodos, desde su conexión inicial hasta su retirada, garantizando la estabilidad de la red en todo momento.

6.1 Proceso de permisionado (alta de nodo)

Objetivo. Autorizar técnicamente la conexión de un nuevo nodo tras verificar su identidad y seguridad.

Ámbito / roles

- **Participante:** Solicitante.
- **Comité de Operaciones y Tecnología:** Verificador y Aprobador.
- **ISBE:** Ejecutor técnico.

Entradas

- Solicitud en Área Privada (*Enode ID*, IP Pública).
- Declaración Responsable de Bastionado (*Checklist)* y firma de "Condiciones de Operación" (Anexo del CMA).
- Informe de auditoría técnica (si aplica).

Pasos

1. **Solicitud:** El Participante registra los datos técnicos del nodo y firma digitalmente las condiciones de operación específicas.
2. **Verificación:** El equipo de Operaciones verifica la conectividad, el *Proxy* y puede auditar el bastionado.
3. **Aprobación:** Validación administrativa de que la entidad está al corriente de obligaciones.
4. **Activación técnica:**
   - **Ejecución:** Inclusión del *Enode ID* en la *allowlist* de los *Bootnodes*.
   - **Consenso:** Propuesta de alta en el *Smart Contract* de Gobernanza para votación *on-chain*.

Salidas

- Nodo conectado y sincronizado.
- Actualización del registro de nodos autorizados.

Plazos / SLA

- **Resolución de solicitud:** ≤ 5 días hábiles.

Evidencias

- Ticket de solicitud en Área Privada.
- *Log* de actualización de la *whitelist* en *Bootnodes*/Contrato.

6.2 Proceso de actualización de software (mantenimiento)

Objetivo. Garantizar que todos los nodos ejecutan versiones compatibles del protocolo para evitar bifurcaciones (*forks*) no deseadas.

Ámbito / roles

- **Comité de Operaciones y Tecnología:** Planificador y Supervisor.
- **Participante:** Ejecutor.

Entradas

- Publicación de una nueva versión estable del cliente (Hyperledger Besu) o *hard fork* programado.
- Notificación de actualización crítica (CVE de seguridad).

Pasos

1. **Comunicación:** ISBE notifica la nueva versión y la ventana de actualización (ej. 15 días) a través del canal oficial.
2. **Despliegue:** El Participante descarga, verifica el *hash* y despliega la actualización en su nodo.
3. **Verificación:** El Participante confirma en el Área Privada que su nodo está actualizado.
4. **Control:** ISBE monitoriza la versión de los nodos conectados. Aquellos no actualizados tras la fecha límite serán desconectados preventivamente para proteger la red.

Salidas

- Parque de nodos actualizado y homogéneo a la versión objetivo.

Plazos / SLA

- **Ventana estándar:** 15 días naturales.
- **Ventana crítica (seguridad):** 48 horas.

Evidencias

- Comunicado oficial de versión.
- *Logs* de versión reportada por los nodos en la red.

6.3 Proceso de baja voluntaria (*Offboarding)*

Objetivo. Permitir la retirada ordenada de un nodo sin afectar a la estabilidad del servicio ni al consenso.

Ámbito / roles

- **Participante:** Solicitante y Ejecutor.
- **Comité de Operaciones y Tecnología:** Supervisor.

Entradas

- Solicitud de baja o parada técnica en el Área Privada.

Pasos

1. **Notificación:** El Participante comunica su intención de baja a través del Área Privada.
2. **Programación:** Se acuerda la fecha de desconexión (al final de la *epoch* en curso para validadores).
3. **Ejecución técnica:**
    a. **Consenso:** Retirada ordenada mediante transacción de baja en el *Smart Contract* (evita penalización por *downtime*).
    b. **Ejecución*:*** Eliminación de la *allowlist*.
4. **Cierre:** Apagado del nodo por parte del Participante.

Salidas

- Nodo desconectado limpiamente y dado de baja en el registro.

Plazos / SLA

- **Preaviso para Nodos de Consenso:** 15 días hábiles.
- **Ejecución de baja:** Inmediata tras el plazo.

Evidencias

- Registro de solicitud de baja.
- Transacción retirada de validador (si aplica):

6.4 Proceso de deshabilitación forzosa (sanción)

Objetivo. Expulsión inmediata de un nodo que viola las reglas o compromete la red.

Ámbito / roles

- **Comité de Operaciones y Tecnología:** Ejecutor.
- **Comité de Seguridad:** Solicitante (en caso de incidente).

Entradas

- Alerta crítica de monitorización (caída sostenida de SLA).
- Reporte de incidente de seguridad.
- Resolución del Órgano de Gestión (sanción).

Pasos

1. **Detección:** Monitorización detecta anomalía crítica (ej. inactividad > 24h, ataque).
2. **Notificación:** Aviso de urgencia al operador para subsanación.
3. **Ejecución:** Si no hay corrección inmediata:
    a. **Ejecución:** *Ban* en *Bootnodes*.
    b. **Consenso:** Transacción de revocación forzosa (*Vote Out*) en el contrato de gobernanza.
4. **Notificación:** Comunicación formal de la sanción.

Salidas

- Nodo aislado de la red (*banned*).
- Pérdida de derechos de validación.

Plazos / SLA

- **Tiempo de reacción:** < 4 horas desde la detección crítica.

Evidencias

- *Logs* de fallo y transacción de revocación.
- Informe de incidente y monitorización.

6.5 Procedimiento de rotación de validadores

Objetivo. Renovación periódica de los validadores activos para garantizar la descentralización.

Ámbito / roles

- ***Smart Contract* de Gobernanza:** Ejecutor automático.
- **Comité de Operaciones y Tecnología:** Supervisor.

Entradas

- Finalización de una *epoch.*
- Existencia de nodos candidatos en estado "Banquillo" (*Stand-by*).

Pasos

1. **Selección:** El algoritmo identifica al validador activo con mayor tiempo de servicio o menor rendimiento.
2. **Sustitución:** Se selecciona el siguiente candidato en la lista de espera (FIFO).

3. **Transición:** En el bloque de transición, el nodo saliente pasa a estado *Stand-by* y el entrante pasa a *Active*.
4. **Verificación:** El sistema confirma la estabilidad del nuevo quórum (> 2/3).

Salidas

- Nuevo conjunto de validadores activos (*Validator Set).*

Plazos / SLA

- **Frecuencia:** Automática según parámetro de red (ej. semanal).

Evidencias

- Evento *ValidatorSetChanged* emitido por el *Smart Contract.*

7. Supervisión, revisión y actualización

Este punto define cómo se controla el cumplimiento de INF1040, cada cuánto se revisa y cómo se actualiza la política cuando cambian las condiciones.

7.1 Objetivo y alcance de la supervisión

El objetivo de la supervisión es garantizar la salud operativa de la infraestructura, asegurando que todos los nodos conectados cumplen con los estándares de rendimiento, seguridad y disponibilidad necesarios para la estabilidad de la red. El alcance abarca la monitorización continua (24/7) de los Nodos de Ejecución y Consenso, permitiendo la identificación proactiva de problemas, la verificación del cumplimiento de SLAs y la toma de decisiones basada en datos para la gestión de la capacidad y la rotación de validadores.

7.2 Indicadores y umbrales (KPI mínimos)

- **Conectividad P2P (*Peer Count*):** Mantenimiento de conexión activa con la red (≥ 1 par). Se considera crítico tener 0 pares durante más de 15 minutos.

- **Sincronización de red (*Block Lag*):** Diferencia de altura con la cabeza de la cadena< 100 bloques (o estado *is_syncing* durante > 30 min).
- **Salud de Recursos (CPU/RAM):** Uso sostenido de CPU y RAM ≤ 95% durante más de 60 minutos para evitar saturación.
- **Almacenamiento disponible:** Espacio libre en disco ≥ 5% en todo momento (riesgo crítico de corrupción de base de datos).
- **Rendimiento de consenso (solo validadores):** Tasa de propuesta de bloques ≥ 70% sobre lo esperado en una *epoch* (ciclo de validación).

7.3 Revisión y actualización de la política

- **Revisión ordinaria:** Anual (cada 12 meses), liderada por el Comité de Operaciones y Tecnología.

- ***Triggers* de revisión extraordinaria:** Actualizaciones mayores del protocolo, publicación de nuevas guías CCN-STIC (ENS) que afecten al bastionado o cambios en la tipología de nodos soportada por Hyperledger Besu.

8. Anexos

8.1 Guía técnica de bastionado

Este anexo detalla las acciones técnicas de obligado cumplimiento para el endurecimiento (*hardening*) del sistema operativo que aloja el nodo. Los operadores deben verificar cada punto antes de la conexión.

	Acción
	Preparación y Seguridad Física
1	Si el equipo es una instalación nueva, se debe proteger del tráfico de red hostil hasta que el sistema operativo sea instalado y bastionado.
2	Definir una contraseña para el BIOS/firmware.
3	Configurar el orden de arranque de los dispositivos para evitar el inicio desde dispositivos externos.
4	Usar la última versión posible de RHEL (si se usa RedHat como Sistema Operativo) o usar la última versión de Software de Ubuntu, CentOs, etc. teniendo en cuenta que los scripts de instalación creados han sido pensados para Ubuntu 22.04
	Configuración del Sistema de Ficheros
5	Crear una partición separada con las opciones nodev, nosuid, and noexec establecidas para /tmp.
6	Crear particiones separadas para /var, /var/log, /var/log/audit y /home.
7	Enlazar el montaje de /var/tmp a /tmp.
8	Establecer la opción nodev a /home.
9	Establecer las opciones nodev, nosuid, and noexec en /dev/shm.
10	Configurar la opción “sticky bit” en todos los directorios escribibles.
	Actualización del Sistema
11	Registrar el sistema en Red Hat Satellite Server para poder recibir actualizaciones y parches o activar actualizaciones automáticas en los otros sistemas operativos diferentes de RedHat
12	Instalar la clave GPG de Red Hat y habilitar el servicio gpgcheck en caso de usar Red Hat
	Configuración Segura de Arranque
13	Establecer Root como propietario de user/group y dar permisos de lectura y escritura

	únicamente a Root en /boot/grub2/grub.cfg.
14	Establecer las password del boot loader.
15	Eliminar el sistema X Window.
16	Deshabilitar el servidor X Font.
	Bastionado de Procesos
17	Restringir core dumps.
18	Habilitar el Randomized Virtual Memory Region Placement.
	Bastionado del Sistema Operativo
19	Eliminar servicios legacy (e.g., telnet-server; rsh, rlogin, rcp; ypserv, ypbind; tftp, tftp-server; talk, talk-server)
20	Deshabilitar cualquier servicio lanzado por xinetd o inetd que no vayan a ser utilizados.
21	Eliminar xinetd, si es posible.
22	Eliminar otros servicios legacy (e.g., chargen-dgram, chargen-stream, daytime-dgram, daytime-stream, echo-dgram, echo-stream, tcpmux-server)
23	Deshabilitar servicios por defecto que no vayan a ser utilizados (e.g., FTP, DNS, LDAP, SMB, DHCP, NFS, SNMP, etc.)
24	Habilitar Daemon umask
	Configuración de la Seguridad de red y de Cortafuegos
25	Limitar conexiones a los servicios habilitados a aquellos usuarios autorizados utilizando firewalls u otras tecnologías de control de acceso.
26	Deshabilitar el IP forwarding.
27	Deshabilitar el envío de paquetes de redirección.
28	Deshabilitar la aceptación de paquetes con la ruta de redirección establecida en origen.
29	Deshabilitar la aceptación de paquetes de redirección ICMP.
30	Ignorar paquetes de peticiones Broadcast.
31	Habilitar la protección contras mensajes Bad error.
32	Habilitar las cookies TCP/SYN.
	Gestión remota usando SSH
33	Establecer el protocolo SSH a 2.
34	Establecer el nivel de logs de SSH a INFO.
35	Deshabilitar el login de Root por SSH.

36	Establecer SSH PermitEmptyPasswords a No.
	Integridad del sistema y detección de intrusiones
37	Instalar y configurar AIDE.
38	Configurar SELinux.
39	Instalar y configurar OSSec HIDS.
	Registro de eventos
40	Configurar Network Time Protocol (NTP). Establecer el huso horario español (GMT +1) basado en el servidor hora.roa.es
41	Habilitar la auditoría del sistema (auditd).
42	Instalar y configurar rsyslog.
43	Todos los accesos Root deben ser auditados.
44	Configurar el envío de logs a un sistema externo (e.g. Splunk).
	Acceso a directorios y ficheros
45	Habilitar y probar los chequeos de integridad sobre cuentas del sistema, membresía a grupos y permisos asociados.
	Configuración PAM
46	Asegurar que los ficheros de configuración de PAM, /etc/pam.d/* son seguros.
47	Establecer el algoritmo de hasheado de passwords a SHA-512.
48	Establecer medidas de robustez en la creación de passwords.
49	Restringir al acceso de Root únicamente a la consola del sistema.
	Paneles de Advertencia
50	Establecer un banner de advertencia en los accesos físicos a la consola del sistema.
51	Establecer un banner de advertencia en los accesos remotos a la consola del sistema
	Consideraciones sobre Antivirus
52	Instalar y habilitar un software Anti-Virus.
53	Configurar la actualización diaria de firmas del Anti-Virus.

Financiado por la Unión Europea NextGenerationEU
Plan de Recuperación, Transformación y Resiliencia
Comunidad de Madrid
ALASTRIA